ISTQB® Certified Tester

Advanced Level — **Security Tester** (CT-SEC, Syllabus 2016)

CHAPTER 7

Security Test Evaluation and Reporting

Complete Study Guide

Chapter fact	Value
Syllabus sections covered	7.1 Security Test Evaluation · 7.2 Security Test Reporting
Learning objectives	4 examinable (AS-7.1.1 – AS-7.2.3) · K2 = 3 · K4 = 1
Recommended teaching time	70 minutes — **5 points**, 4.3 points per teaching hour
Questions in the exam	**3 of 45 questions · 5 of 80 points.** K2 = 2 · **K4 = 1**. Guaranteed: **AS-7.1.1** (K2) and **AS-7.2.3** (K4). One K2 from 7.2.1/7.2.2
Exam format	45 questions · **80 points** · **120 minutes** (150 with the 25% non-native-language allowance) · pass mark 65% = **52 points** · K2 = 1 pt · K3 = 2 pts · K4 = 3 pts
Keywords	acceptance criteria · attack vector · dashboard · exit criteria
Official sample-exam questions	**#38 – #40** (1 + 1 + 3 points)

Built exclusively from the ISTQB® Advanced Level Security Tester syllabus (2016), the official Sample Exam (questions and answers, GA March 2016) and the ISTQB® exam structure tables.

Study this single file to master Chapter 7.

Contents

Section 1 — Syllabus Explanation....4
AS-7.1.1 (K2) — Security Test Evaluation....4
AS-7.2.1 (K2) — Confidentiality of Security Test Results....5
AS-7.2.2 (K2) — Controls and Data Gathering for Status Reporting....5
AS-7.2.3 (K4) — Analyzing Interim Security Test Status Reports....5
Section 2 — Key Concepts....7
2.1 The storyline of Chapter 7....7
2.2 Evaluation and reporting....7
2.3 Fuzzy points clarified....9
2.4 Chapter 7 keyword glossary....9
Section 3 — Tables and Summaries....10
Section 4 — Demo Questions with Answers....11
Part A — The 3 official Chapter 7 questions....11
Part B — 13 additional syllabus-derived questions....12
Most Important Questions From This Chapter....15
Section 5 — Exam Tricks....16
5.1 Frequently tested topics (evidence-based)....16
5.2 Common distractors observed....16
5.3 Keyword recognition (map words → answers)....16
5.4 Typical traps....16
5.5 How to eliminate wrong answers....16
5.6 Scenario-solving shortcuts....17
5.7 Common candidate mistakes....17
5.8 Mnemonics that carry the whole chapter....17
5.9 Chapter 7 mind map....17
Section 6 — Revision Notes....18
6.1 One-page chapter summary....18
6.2 Key definitions to memorize....18
6.3 High-priority concepts (study first)....18
6.4 Last-minute revision sheet....18
6.5 Memorization checklist....18
6.6 Exam-day quick review....18

In Word, right-click the table of contents and choose "Update Field" → "Update entire table" to refresh the page numbers.

How to use this guide

Section 1 explains the four learning objectives. **Section 2** explains every key concept from the ground up — plain words, how it works, a worked example, the exam angle, and what it is easily confused with — and ends with the chapter's **fuzzy points clarified**. If the syllabus wording in Section 1 feels dense, read the matching Section 2 card first. **Section 3**, **table 3.1 (where does it go in the report?)**, is the K4 in table form. **Section 4** is the question bank, **Section 5** exam tactics, **Section 6** is the revision sheet for the night before.

What makes Chapter 7 unusual: three questions, and **one of them is worth 3 points** — analyzing a security test status report for **accuracy, understandability and stakeholder appropriateness**.

The rule that decides it: risk impact goes in the summary and is detailed later by specific vulnerability, and **security results go only to those who need to know** — "the fewer people that know the better".

Suggested schedule: one session for Sections 1–3, one for Sections 4–5; redo missed questions and re-read Section 2's fuzzy points; Section 6 the night before.

Section 1 — Syllabus Explanation

Chapter 7, **Security Test Evaluation and Reporting**, carries **4 learning objectives** across two sub-chapters (7.1 Evaluation · 7.2 Reporting). The Exam Structure Table allocates **3 questions** and **5 of the 80 points**. Teaching time is **70 minutes — 4.3 points per teaching hour**.

One question is a **3-point K4** on **analyzing an interim status report (AS-7.2.3) — 60% of the chapter**. The rest are two K2s: one guaranteed on **revising expectations and acceptance criteria (AS-7.1.1)**, one from **confidentiality** or **controls and data gathering** (AS-7.2.1 / 7.2.2).

LO ID	K	Objective (syllabus statement)	Qs	Pts
AS-7.1.1	K2	Understand the need to revise security expectations and acceptance criteria as the scope and goals of a project evolve.	**1**	1
AS-7.2.1	K2	Understand the importance of keeping security test results confidential and secure.	1 of 2†	1
AS-7.2.2	K2	Understand the need to create proper controls and data-gathering mechanisms to provide the source data for the security test status reports in a timely, accurate, and precise fashion (e.g. a security test dashboard).	1 of 2†	1
AS-7.2.3	**K4**	Analyze a given interim security test status report to determine the level of accuracy, understandability, and stakeholder appropriateness.	**1**	**3**
Chapter 7 total	—	**K2 = 2 · K4 = 1**	**3**	**5**

*† One K2 drawn from AS-7.2.1 / 7.2.2 — the Sample Exam drew **7.2.1** (Q39).*

Exam allocation you must know

Chapter 7 = **3 questions / 5 points**; Sample Exam **#38 to #40** (1 + 1 + 3 points).

The one thing that decides this chapter

Summary up top, detail below — and the fewer people who see it, the better. The 3-point report question (Q40) is answered by **risk impact described in the summary and later detailed in terms of specific vulnerabilities**: not the full assessment in the summary, not risk only at the end, and never absent. The confidentiality question (Q39) is answered by **"the fewer people that know the better."**

AS-7.1.1 (K2) — Security Test Evaluation

Original syllabus statement

Understand the need to revise security expectations and acceptance criteria as the scope and goals of a project evolve.

- **Measuring security test results and evaluating status against security expectations, exit criteria and/or acceptance criteria are required to determine test completion.**
- **It is difficult to know all the security risks at the outset of a project.**
- **Stakeholder and user expectations sometimes change** regarding the level of security needed — e.g. **awareness of a new threat** might cause stakeholders to **require higher levels of security** than initially thought.
- **This is one reason why security risk assessments need to be revisited throughout a project**, and the results **incorporated into security test planning and execution**.

How the official exam used this objective

Sample Q38: why reassess security risk expectations frequently? **Stakeholders will make business decisions based on associated**

security risk levels — they decide **which risk level is acceptable** and on **mitigation plans**. Rejected: stakeholders educated on **all risks at all times** (**everyone doesn't need to know everything**); a **manual risk mitigation plan by users** (not feasible); expectations **kept from changing** (**expectations should change**).

AS-7.2.1 (K2) — Confidentiality of Security Test Results

Original syllabus statement

Understand the importance of keeping security test results confidential and secure.

- The average tester **knows more about the test object after testing** than most developers or designers — the **most important weaknesses and strong points**. The same applies to security testing, which may find **hidden holes and vulnerabilities**.
- **The difference lies in the possible negative impact of communicating these vulnerabilities to people other than the direct stakeholders.**
- **Information should be made available only to those who need to know** — and **being conservative with sharing security test results is considered good practice**.

How the official exam used this objective

Sample Q39: important aspect of security test results? **The fewer people that know the better** — results should be **kept confidential and access tightly controlled**, because they identify weaknesses, and **often the same issues exist in production**. Rejected: **published for users and stakeholders**; **shared with developers across the enterprise** (only **limited parts** to developers to improve coding, and to **infrastructure people** to fix infrastructure issues); **always classified by criticality** (true, but **not the most important aspect**).

AS-7.2.2 (K2) — Controls and Data Gathering for Status Reporting

Original syllabus statement

Understand the need to create proper controls and data-gathering mechanisms to provide the source data for the security test status reports in a timely, accurate, and precise fashion (e.g. a security test dashboard).

- **The impact of a security vulnerability is normally judged more sensitive than "normal" defects**, so reporting must be **more precise and accurate** about **the nature of the defect and the implied risks**.
- **In most projects security defects are categorized with a higher severity than comparable functional defects** — so **management has a higher focus** on them, their risks and resolutions.
- Security defect reporting must **carefully assess the impact**, **the accuracy of test results**, and be **available in a well-defined and timely manner**.
- **Good practice: discuss with management how and when they would like access to security defect reports** (e.g. a **dashboard**).

AS-7.2.3 (K4) — Analyzing Interim Security Test Status Reports

Original syllabus statement

Analyze a given interim security test status report to determine the level of accuracy, understandability, and stakeholder appropriateness.

Reports may be produced **throughout testing** or **only at the end** (end of system security testing, or of acceptance-level security tests). **Early security test reporting is encouraged because it allows more time to remediate vulnerabilities.** Following this syllabus's process, the team may discover vulnerabilities and document observations **during all test activities**.

The eight sections of a security test report

#	Section	Contents
1	**Report identifier**	—
2	**Summary**	a. **Executive summary** · b. **Key findings**
3	**Variances**	a. **Test process followed** · b. **Variances from the planned process** · c. **Methods and tools** (configurations, policies) used
4	**Comprehensive assessment**	a. **Evaluation of test coverage** against the criteria in the test plan · b. **Explanation for items or features not tested**
5	**Summary of results**	a. Summarization of results · b. **All resolved vulnerabilities and their resolutions** · c. **All unresolved vulnerabilities**
6	**Evaluation**	a. Evaluation of results and status **against exit criteria** · b. **Risks identified (classifications) and impact of unresolved vulnerabilities**
7	**Summary of activities**	—
8	**Approvals**	—

Effectiveness of security test reporting depends on...

Factor	Question to ask of a given report
Timing	Is it early enough to allow remediation? Interim, not only final?
Content	Are all eight sections there, accurate and precise? Unresolved vulnerabilities and their risk impact stated?
Recipients	Is the audience authorized and need-to-know?
Tuning to recipients' needs	Is the level of detail right for them? **An executive report differs from one for a system architect. Multiple reports** may be needed

How the official exam used this objective (K4, 3 points)

Sample Q40: a high-risk project is ready for deployment and you want **particular emphasis on risk**. Best way to articulate it? **Risk impact described in the summary and later detailed in terms of specific vulnerabilities.**

Rejected: **a descriptive risk assessment in the summary** (**details should not be in the summary**); **overall risk only in the last section** (**should not be recorded only at the end**); **risk not in the summary** (**an important part of the report**). Structure: **Summary (2: executive summary, key findings) → Evaluation (6b: risks and impact of unresolved vulnerabilities)**.

K4 method — the three tests of a status report

Accuracy: are numbers consistent (resolved + unresolved = found)? Are coverage claims backed by the plan's criteria? Are untested items explained?

Understandability: is there an executive summary with key findings? Is risk stated in business terms before technical detail?

Stakeholder appropriateness: is sensitive detail (exploit steps, unresolved vulnerability specifics) limited to need-to-know readers? Does each audience get the level of detail it needs?

Section 2 — Key Concepts

Section 1 gives the syllabus wording objective by objective. This section explains what that wording means. Each card builds one idea in order: plain words first, then how it works, an example, how the exam uses it, and what it is easily confused with.

2.1 The storyline of Chapter 7

Chapter 7 is about the **end of the test process**: deciding whether testing is done, and telling people what was found. Two things make this harder for security than for ordinary testing. **First, the target moves:** what counts as "secure enough" changes as new threats appear, so expectations and acceptance criteria must be **revisited**. **Second, the results are dangerous:** a list of vulnerabilities helps attackers, so it goes **only to those who need to know**, and each audience gets **the level of detail it needs**: a summary of risk impact at the top, specifics further down.

2.2 Evaluation and reporting

Revising security expectations and acceptance criteria (AS-7.1.1, guaranteed K2)	
In plain words	Testing is complete when results meet the **security expectations, exit criteria and/or acceptance criteria**. But you **cannot know every security risk at the start** of a project, and stakeholders may **change their minds** about how much security they need. So the criteria must be **revised as the project evolves**.
How it works	**Measure** the results and **evaluate status** against the expectations and criteria to decide whether testing is complete. **New threats change expectations.** For example, news of a new attack makes stakeholders demand **more** security than they first asked for. That is why **security risk assessments are revisited throughout the project**, and their results **fed back into test planning and execution**.
Example	Halfway through a project, a widely reported attack on a competitor exploits weak multi-factor fallback via SMS. The product owner now requires app-based MFA. The acceptance criteria, the risk assessment and the remaining test plan are all updated, and "SMS fallback works" is **no longer** an acceptable result.
Exam angle	Official Q38: why reassess security risk expectations frequently? → **Stakeholders make business decisions based on the associated risk levels** (what risk is acceptable, and which mitigation plans to fund). Reject: everyone educated on **all** risks at **all** times, a **manual** user mitigation plan, and keeping expectations **from changing** (they **should** change).
Don't confuse	**Revising** criteria because the risk picture changed is correct. **Lowering** criteria just to declare testing finished is not what the syllabus means.

Keeping security test results confidential (AS-7.2.1, K2 pool)	
In plain words	After testing, the tester knows the system's **weak points better than almost anyone**. With security testing, those weak points are **ways in for an attacker**. So results are shared **only with those who need to know**, and **being conservative with sharing is good practice**.
How it works	The difference from ordinary testing is the **possible negative impact of telling people other than the direct stakeholders**. Developers get the **limited parts** they need to fix the code. **Infrastructure staff** get the infrastructure findings. Often **the same issues exist in production**, so a leaked test report can be an immediate attack guide.
Example	A penetration test finds that the HR portal allows privilege escalation. The full report goes to the security manager and the HR system owner. The developers get the specific defect and the steps to reproduce it. The company-wide newsletter says only that "a security test of HR systems was completed and findings are being addressed".
Exam angle	Official Q39: the important aspect of security test results → **the fewer people that know, the better.** Reject: publishing them to users and stakeholders, sharing them with **all** developers across the enterprise, and "always classify by criticality" (true, but not the **most important** aspect).

Keeping security test results confidential (AS-7.2.1, K2 pool)	
Don't confuse	**Need to know** is not **secrecy from everyone**. Stakeholders who must decide or act get what they need, at the right level of detail.

Controls and data-gathering for status reporting (AS-7.2.2, K2 pool)	
In plain words	Security defects are judged **more sensitive** than ordinary defects and are usually given a **higher severity**, so **management watches them more closely**. The data behind security status reports must therefore be **timely, accurate and precise**, and collected through **proper controls**, for example feeding a **security test dashboard**.
How it works	Report the **nature of each defect and its implied risk** precisely. Assess the **impact** carefully and check the **accuracy** of the test results before reporting. Make reports available in a **well-defined, timely** way. **Good practice:** ask management **how and when** they want to see security defect information (dashboard, weekly briefing, immediate alert for critical issues).
Example	Management agrees with the test manager that new critical security findings are reported to the CISO **within four hours**, while the dashboard shows open security defects by severity, updated nightly from the restricted category of the defect tracker. The data is only as good as the tracker, so testers must log consistently.
Exam angle	If an option makes security reporting **less** precise or **slower** than functional reporting, it is wrong. The syllabus wants it **more** precise and accurate because of the higher severity and focus.
Don't confuse	A dashboard is **an example** of a data-gathering and reporting mechanism, not a requirement. The point is **timely, accurate, precise** source data.

Analyzing an interim security status report (AS-7.2.3, guaranteed K4)	
In plain words	Reports can be produced **during** testing (interim) or **at the end**. **Early reporting is encouraged, because it leaves more time to fix vulnerabilities.** A good security report follows an **eight-section structure** and is judged on **accuracy, understandability and stakeholder appropriateness**.
How it works	**The eight sections: 1 identifier · 2 summary** (2a **executive summary**, 2b **key findings**) **· 3 variances** (process followed, deviations, methods and tools) **· 4 comprehensive assessment** (coverage against the plan's criteria, and **why items were not tested**) **· 5 summary of results** (**resolved** vulnerabilities and their fixes, and **unresolved** ones) **· 6 evaluation** (status **against exit criteria**, and **risks and the impact of unresolved vulnerabilities**) **· 7 summary of activities · 8 approvals**. **Effectiveness depends on: timing** (early enough to act) **· content** (accurate and complete) **· recipients** (authorized, need-to-know) **· tuning to the recipients** (an executive report differs from one for a system architect; **several reports** may be needed).
Method	**Accuracy:** do the numbers add up (found = resolved + unresolved)? Are coverage claims backed by the plan's criteria? Are untested items explained? **Understandability:** is there an executive summary with key findings? Is risk stated in **business** terms before the technical detail? **Stakeholder appropriateness:** is exploit-level detail restricted to need-to-know readers? Does each audience get the level of detail it needs?
Example	An interim report for the board lists 14 open vulnerabilities with CVE numbers and exploit steps on page 1, and states the overall risk only on the last page. **Problems:** wrong audience detail (exploit steps for a board), the risk impact is **not in the summary**, and confidentiality is broken. **Fix:** the summary states the business risk impact. Section 6 details the risk by vulnerability. Exploit steps go to the technical report only.

Analyzing an interim security status report (AS-7.2.3, guaranteed K4)	
Exam angle	Official Q40 (3 points): for a high-risk project, articulate risk as **risk impact in the summary, then detailed in terms of specific vulnerabilities later.** Reject a full risk assessment in the summary, risk only in the last section, and no risk in the summary at all.
Don't confuse	**Summary** = headline impact (what it means for the business). **Section 6b** = the detailed risks and the impact of each unresolved vulnerability. The answer needs **both**, in that order.

2.3 Fuzzy points clarified

Places where the wording is easy to misread

The three report-quality tests (accuracy, understandability, stakeholder appropriateness) come from the learning objective. The checks under each are this guide's method. The syllabus gives the eight sections and the four effectiveness factors.

"Summary" appears twice in the eight sections. Section 2 is the **summary** (executive summary and key findings). Section 5 is the **summary of results** (resolved and unresolved vulnerabilities). Q40's "summary" is section 2.

"The fewer the better" does not mean no report. It means restricted distribution. Q40 still wants risk **in** the summary, for the authorized audience.

Interim vs final. The syllabus encourages **early** (interim) reports because they leave more remediation time. A final report may **also** need to be confidential, depending on whether the vulnerabilities have been fixed (Chapter 3).

2.4 Chapter 7 keyword glossary

Keyword	Working definition for the exam
acceptance criteria	Criteria a system must satisfy to be accepted; security needs belong in them and may need revising as goals evolve.
attack vector	A path or means by which an attacker gains access to a system.
dashboard	A representation of test status for timely management access; an example of a data-gathering and reporting mechanism.
exit criteria	Conditions for completing testing; security results are evaluated against them (report section 6a).

Section 3 — Tables and Summaries

3.1 Where does it go in the report?

Item	Section
Headline risk impact for executives	**2a Executive summary**
Top three findings	**2b Key findings**
We skipped the mobile app because the build was late	**4b** (not tested — explanation)
We used a different scanner than planned	**3b / 3c** (variance; tools)
Coverage against plan criteria	**4a**
Fixed SQL injection in login (resolution)	**5b**
Open privilege escalation	**5c**, with risk and impact in **6b**
Status vs exit criteria	**6a**
Sign-offs	**8**

3.2 Who gets what?

Audience	Content focus	Sensitivity handling
Executive management	Business risk impact, decisions needed	No exploit detail
Security / test manager	Full report	Need-to-know
Developers	Specific defects to fix, coding lessons	**Limited parts** only
Infrastructure staff	Infrastructure issues to fix	**Limited parts** only
System architect	Design-level weaknesses	Need-to-know
General stakeholders / users	Not the vulnerability detail	**The fewer the better**

Reproduce from memory before moving on

The eight report sections and **where risk goes (2 and 6b)** — the 3-point K4.

Why revisit expectations — the guaranteed K2.

Need to know / fewer is better and **higher severity, precise, timely** — the pooled K2.

Section 4 — Demo Questions with Answers

*Questions 1–3 are the **official ISTQB CTAL-SEC Sample Exam questions for Chapter 7** — #38 to #40 — with official answers and rationale. LO tags are inferred and match the Exam Structure Table. Questions 4–16 are derived strictly from the syllabus. Correct options are marked ✔.*

Part A — The 3 official Chapter 7 questions

Q1. OFFICIAL · Sample Exam #38 (1 pt)

Why is it important to reassess security risk expectations on a frequent basis?

a) Stakeholders have to be educated on all security risks at all times

b) Stakeholders will make business decisions based on associated security risk levels ✔

c) Users must develop a manual-based risk mitigation plan

d) Both user and stakeholder expectations regarding security should be kept from changing

Correct answer: b | LO: AS-7.1.1 (K2) | Syllabus §7.1

Why: (b) — official rationale: **stakeholders often have to make business decisions regarding the security risk level that is acceptable and any necessary mitigation plans.** (a) **everyone doesn't need to know everything**. (c) **a manual-based risk mitigation plan is not feasible and the users probably wouldn't be implementing this anyway**. (d) **expectations should change**.

Q2. OFFICIAL · Sample Exam #39 (1 pt)

Which of the following is an important aspect of security test results?

a) They are published for users and stakeholders to access in order to help them better understand risk

b) They should be shared with developers across the enterprise in order to mitigate risk for future development projects

c) The fewer people that know the better ✔

d) Results should always be classified by criticality

Correct answer: c | LO: AS-7.2.1 (K2) | Syllabus §7.2.1

Why: (c) — official rationale: **the results from security tests should be kept confidential and access to the results should be tightly controlled. This is because the outcome of the tests often identify weaknesses in the current system under test and often the same issues exist with the production system.** (a) **because of the need to tightly control access**. (b) **only limited parts of the report should be made available to the developers to improve their coding. Likewise, limited parts should be made available to infrastructure people.** (d) **is true, but is not the most important aspect**.

Q3. OFFICIAL · Sample Exam #40 (3 pts)

You are finalizing your security test status report for a project that is ready for deployment into production. There is a high degree of risk for this project due to the nature of the system. As a result, you want to place particular emphasis on risk. Based on this, what is the best way to articulate risk on your report?

a) A descriptive risk assessment included in the summary

b) Overall risk included in the last section of the report

c) Risk impact described in the summary and later detailed in terms of specific vulnerabilities ✔

d) Risk impact is not part of the summary of the report

Correct answer: c | LO: AS-7.2.3 (K4) | Syllabus §7.2.3

Why: (c) — official rationale: **the risk impact should be described in the summary and detailed later in the report by discussing specific vulnerabilities.** (a) **the details should not be in the summary**. (b) **the information should not be recorded only at the end of the report**. (d) **this is an important part of the report**.

Part B — 13 additional syllabus-derived questions

*The K-level in each question's label is the level of the **learning objective** it practises, not of the question itself. Some Part B items are quick recall checks on a K3 or K4 objective. Use them to learn the facts, and use the scenario items (and Part A) to practise the reasoning the real K3/K4 questions need.*

Q4. Derived from syllabus

Midway through a project, a widely publicized attack on a competitor makes stakeholders demand stronger authentication. What does the syllabus recommend?

a) Revisit the security risk assessment and incorporate the results into security test planning and execution, revising expectations and acceptance criteria ✔

b) Keep the original acceptance criteria to avoid scope creep

c) Defer any change until the next project

d) Ask users to write a manual mitigation plan

Correct answer: a | LO: AS-7.1.1 (K2) | Syllabus §7.1

Why: (a) — §7.1: **awareness of a new threat might cause stakeholders to require higher levels of security than initially thought. This is one reason why security risk assessments need to be revisited throughout a project and the results incorporated into security test planning and execution.**

Q5. Derived from syllabus

Against what are security test results measured to determine test completion?

a) The number of test cases executed

b) The number of hours spent

c) The developers' estimates

d) Security expectations, exit criteria and/or acceptance criteria ✔

Correct answer: d | LO: AS-7.1.1 (K2) | Syllabus §7.1

Why: (d) — §7.1.

Q6. Derived from syllabus

What makes communicating security test results different from communicating other test results?

a) Security testers know less about the system than developers

b) The possible negative impact of communicating vulnerabilities to people other than the direct stakeholders ✔

c) Security results are always less accurate

d) Security results do not need to be reported

Correct answer: b | LO: AS-7.2.1 (K2) | Syllabus §7.2.1

Why: (b) — §7.2.1. Hence information should be available **only to those who need to know**.

Q7. Derived from syllabus

A product owner asks for the full penetration test report to be attached to the public release notes "for transparency". What is the best response?

a) Agree, since transparency builds trust

b) Agree, but remove the tester names

c) Decline: results should be available only to those who need to know; sharing conservatively is good practice, especially while vulnerabilities may be unresolved or also present in production ✔

d) Publish only the unresolved vulnerabilities

Correct answer: c | LO: AS-7.2.1 (K2) | Syllabus §7.2.1

Why: (c) — §7.2.1 and the official Q39 rationale. (d) would be the most harmful option.

Q8. Derived from syllabus

Why must security defect reporting be especially precise and accurate?

a) Security vulnerabilities are judged more sensitive, are usually categorized with higher severity than comparable functional defects, and receive higher management focus ✔

b) Because security defects are always cheaper to fix

c) Because developers dislike vague reports

d) Because security defects are rarely fixed

Correct answer: a | LO: AS-7.2.2 (K2) | Syllabus §7.2.2

Why: (a) — §7.2.2.

Q9. Derived from syllabus

Which practice does the syllabus recommend for giving management access to security defect reports?

a) Email every new defect to all managers immediately

b) Provide reports only at project end

c) Let each tester decide individually

d) Discuss with management how and when they would like access to the security defect reports — e.g. a security test dashboard ✔

Correct answer: d | LO: AS-7.2.2 (K2) | Syllabus §7.2.2

Why: (d) — §7.2.2 and the LO's own example of a **dashboard**.

Q10. Derived from syllabus

Which three qualities must the source data for security test status reports have, according to the learning objective?

a) Cheap, fast, simple

b) Timely, accurate and precise ✔

c) Public, complete, permanent

d) Automated, visual, colourful

Correct answer: b | LO: AS-7.2.2 (K2) | Syllabus §7.2.2

Why: (b) — AS-7.2.2: **in a timely, accurate, and precise fashion**.

Q11. Derived from syllabus

Why does the syllabus encourage early security test reporting?

a) It reduces the number of reports

b) It satisfies auditors

c) It allows more time to remediate security vulnerabilities ✔

d) It makes final reports unnecessary

Correct answer: c | LO: AS-7.2.3 (K4) | Syllabus §7.2.3

Why: (c) — §7.2.3.

Q12. Derived from syllabus

Interim report extract — Summary: "Testing is going well." Results: 42 vulnerabilities found; 30 resolved; 9 unresolved (list attached with exploit steps). Coverage: "Most areas tested." Distribution: all 120 project members and the client's procurement team.

Which assessment of accuracy, understandability and stakeholder appropriateness is best?

a) Inaccurate (30 + 9 ≠ 42; coverage not evaluated against plan criteria; untested items not explained), not understandable (no executive summary of key findings or risk impact), and inappropriate distribution (unresolved vulnerabilities with exploit steps sent far beyond need-to-know) ✔

b) Acceptable — it reports numbers and coverage

c) Only the distribution is a problem

d) Only the summary is a problem

Correct answer: a | LO: AS-7.2.3 (K4) | Syllabus §7.2.3

Why: (a) checks all three dimensions: **accuracy** (counts don't reconcile; section 4 requires **coverage against the plan's criteria** and **explanation of untested items**), **understandability** (section 2 needs an **executive summary and key findings**; risk and impact of unresolved vulnerabilities belong in 6b), **appropriateness** (**need to know**; recipients and **tuning** determine effectiveness).

Q13. Derived from syllabus

In which report section should the explanation for items or features that were not tested appear?

a) Summary of activities

b) Variances

c) Approvals

d) Comprehensive assessment ✔

Correct answer: d | LO: AS-7.2.3 (K4) | Syllabus §7.2.3

Why: (d) — section 4: **(a) evaluation of test coverage based on the criteria in the test plan; (b) explanation for any items or features that were not tested**.

Q14. Derived from syllabus

A test team used a different vulnerability scanner than planned and changed its configuration. Where should this be reported?

a) Summary of results

b) Variances — test process followed, variances from the planned process, and methods and tools used ✔

c) Evaluation

d) Report identifier

Correct answer: b | LO: AS-7.2.3 (K4) | Syllabus §7.2.3

Why: (b) — section 3.

Q15. Derived from syllabus

On what four things does the effectiveness of security test reporting depend?

a) Length, layout, language, logo

b) Number of defects, number of testers, budget, schedule

c) Timing of the report, content, recipients, and tuning of the content to match the recipients' need ✔

d) Tool used, format, frequency, approver

Correct answer: c | LO: AS-7.2.3 (K4) | Syllabus §7.2.3

Why: (c) — §7.2.3; **multiple reports** may be needed — **an executive report differs from one for a system architect**.

Q16. Derived from syllabus

In which section is the impact of unresolved security vulnerabilities evaluated?

a) Evaluation (risks identified and impact of unresolved vulnerabilities) ✔

b) Variances

c) Approvals

d) Report identifier

Correct answer: a | LO: AS-7.2.3 (K4) | Syllabus §7.2.3

Why: (a) — section 6b. The headline risk impact also appears in the **summary** (Q3).

Most Important Questions From This Chapter

*Ranking rationale: guaranteed **AS-7.1.1 (K2)** and **AS-7.2.3 (K4)**; one K2 from 7.2.1 / 7.2.2.*

Rank	Topic / question focus	LO	Why it matters
1	Report structure and analysis — Q3, Q11–Q16	AS-7.2.3	**Guaranteed 3 points.**
2	Revisiting expectations — Q1, Q4, Q5	AS-7.1.1	**Guaranteed 1 point.**
3	Confidentiality — Q2, Q6, Q7	AS-7.2.1	Pooled 1 point; “fewer the better”.
4	Precision, severity, dashboard — Q8–Q10	AS-7.2.2	Pooled 1 point.

Section 5 — Exam Tricks

5.1 Frequently tested topics (evidence-based)

LO	K	Pts	Sample #	Format used officially
AS-7.1.1	K2	1	#38	Why reassess risk expectations? → **stakeholders make business decisions on risk levels**
AS-7.2.1	K2	1	#39	Important aspect of results → **the fewer people that know the better**
AS-7.2.3	**K4**	**3**	#40	How to articulate risk → **summary + detailed vulnerabilities later**
Chapter 7 total	—	**5**	**#38–#40**	**Three questions, one rule each**

> **The arithmetic**
>
> **5 points for 70 minutes.** The K4 alone is **3 points** and turns on **one structural fact**: risk impact sits in the **summary** and is **detailed later** by vulnerability.

5.2 Common distractors observed

- **Educate everyone on all risks** — need-to-know instead.
- **Freeze expectations** — they **should** change.
- **Publish or share widely** — conservative sharing.
- **"Always classify by criticality"** — true but not the **most important** aspect.
- **Detail in the summary** / **risk only at the end** / **no risk in the summary** — all wrong for a risk-heavy report.

5.3 Keyword recognition (map words → answers)

If the stem says...	Think...
"reassess", "expectations change", "new threat"	**Revisit risk assessment; stakeholders decide acceptable risk**
"who should see results"	**Need to know — fewer the better**
"developers across the enterprise"	**Limited parts** only
"higher severity", "management focus"	**Precise, accurate, timely** reporting
"dashboard"	**Agree how and when** management accesses defect reports
"emphasis on risk" in a report	**Summary + later detail**
"not tested"	**Comprehensive assessment (4b)**
"different tool than planned"	**Variances (3)**
"executive vs architect"	**Multiple reports, tuned content**

5.4 Typical traps

- **Interim vs final** — interim reports are **encouraged** (more time to remediate).
- **Key findings** live in the **summary**, not in the results section.
- **Resolved and unresolved** vulnerabilities are both listed (5b and 5c).

5.5 How to eliminate wrong answers

1. Strike anything that **widens access** to results.

2. Strike anything that **freezes** expectations or criteria.
3. In structure questions, strike options that put **all detail in the summary** or **nothing in it**.

5.6 Scenario-solving shortcuts

Scenario shape	Shortcut
Report to analyze	Check **accuracy** (numbers, coverage vs plan, untested explained) → **understandability** (executive summary, key findings, risk) → **appropriateness** (need to know, tuned)
Stakeholders' needs changed	**Revisit risk assessment; revise criteria**
Request to share results	**Need to know**; limited parts to those who fix

5.7 Common candidate mistakes

- Treating this as a Foundation-level reporting chapter — the twist is **confidentiality**.
- Forgetting **Approvals** as the last section.

5.8 Mnemonics that carry the whole chapter

Mnemonic	Expands to
I-S-V-C-R-E-A-A ("I Seldom Verify Critical Results Except At Approval")	**I**dentifier, **S**ummary, **V**ariances, **C**omprehensive assessment, **R**esults summary, **E**valuation, **A**ctivities summary, **A**pprovals
T-C-R-T	Reporting effectiveness: **T**iming, **C**ontent, **R**ecipients, **T**uning
"Top line, then detail"	Risk impact in the summary, detailed later
"Need to know"	Confidentiality of results

5.9 Chapter 7 mind map

Branch	Leaves
Evaluation	Against expectations, exit and acceptance criteria · risks unknown at outset · expectations change · revisit risk assessment
Confidentiality	Tester knows weaknesses · negative impact of sharing · need to know · conservative
Controls & data	More sensitive · higher severity · management focus · precise, accurate, timely · agree access (dashboard)
Report	Early encouraged · eight sections · timing, content, recipients, tuning · multiple reports

Section 6 — Revision Notes

6.1 One-page chapter summary

Completion is judged against security expectations, exit and acceptance criteria — which change as risks and stakeholder expectations change, so the risk assessment is revisited throughout. Security results reveal weaknesses that may also exist in production; share them only on a need-to-know basis. Security defects are more sensitive and severe, so their reporting must be precise, accurate and timely, through mechanisms such as a dashboard agreed with management. Report early. A report has eight sections; risk impact is summarised up front and detailed by vulnerability later; effectiveness depends on timing, content, recipients and tuning, often with different reports for different audiences.

6.2 Key definitions to memorize

Term	Definition
Need to know	Make security information available only to those who need it
Security test dashboard	Mechanism for timely, accurate, precise status access
Interim report	Report during testing — encouraged to allow remediation time

6.3 High-priority concepts (study first)

4. Eight report sections; risk in summary + evaluation (3 pts).
5. Revisit expectations (1 pt).
6. Need to know; precision and severity (1 pt).

6.4 Last-minute revision sheet

If you read nothing else

Expectations change → revisit risk assessment; stakeholders decide acceptable risk.

Results: **the fewer people that know the better**; limited parts to developers and infrastructure.

Security defects: higher severity, precise, timely, dashboard.

Report: Identifier · Summary (exec, key findings) · Variances · Comprehensive assessment · Results · Evaluation · Activities · Approvals.

Risk: **summary + later detail by vulnerability**.

6.5 Memorization checklist

✓	I can...
☐	explain why acceptance criteria and expectations are revised
☐	explain need-to-know for security results
☐	explain why security defect reporting must be precise and timely
☐	list the eight report sections with subsections
☐	assess a report for accuracy, understandability and appropriateness

6.6 Exam-day quick review

Top line, then detail. Fewer is better. Expectations should change.